

DOKUMEN PRODUK · ATUMCELL

CONTINUOUS ASSURANCE (IT)

Penjelasan fitur beserta alasan wajib ada, serta positioning terhadap kompetitor — dengan fokus khusus pada Rapid7 (Vector Command & Exposure Command).

Versi · 1.0 · 14 September 2026

Tujuan · Briefing internal / diskusi lead (Matthew & tim)

Produk · Continuous Assurance (IT) — bukan OT

Prototype · ca-app (React) · mockup HTML · PRD terpisah

Inti nilai · Continuous discovery + human validation + verified closure

1. RINGKASAN PRODUK

Continuous Assurance (IT) adalah keyakinan berkelanjutan atas postur keamanan **eksternal** organisasi. Produk memantau attack surface secara terus-menerus, memvalidasi temuan penting dengan manusia (selaras keahlian pentest Atumcell), lalu menutup temuan hanya setelah retest — lengkap dengan **sertifikat penutupan bertanggung**.

Bukan compliance automation (Vanta/Drata). **Bukan** security rating murni (Bitsight). **Ya**: monitoring eksternal + validasi manusia + penutupan terverifikasi + keluaran untuk auditor, asuransi, dan sponsor PE.

Masalah yang dijawab: scan otomatis menghasilkan banyak noise; pentest tahunan dalam tapi cepat kedaluwarsa. CA mengisi celah di tengah.

2. FITUR INTI & ALASAN HARUS ADA

Setiap fitur di bawah dipetakan ke kebutuhan buyer (CISO mid-market / engineer / sponsor PE) dan ke diferensiator vs pasar. Feedback Matthew: overview harus menonjolkan **overall risk score** dan **top issues to remediate**.

2.1 Overview — Overall risk score + grade + tren

Skor eksposur, grade, delta periode, last sweep, tren 12 minggu.

Mengapa wajib: Eksekutif butuh satu angka untuk board/IC. Tanpa skor, produk terasa seperti daftar ticket teknis. Ini juga permintaan eksplisit dari lead (“Overall risk score”). Skor harus jujur — tidak menyembunyikan bahwa sebagian aset masih unscanned.

2.2 Overview — Top issues to remediate

Antrian prioritas: critical / high / KEV, dengan status validasi dan SLA.

Mengapa wajib: Skor tanpa aksi tidak berguna. Lead meminta “Top issues to remediate” agar layar pertama langsung menjawab: apa yang harus dikerjakan sekarang. Ini membedakan CA dari dashboard rating yang berhenti di skor.

2.3 Pemisahan coverage: human-validated / automated / unscanned

Metrik dan badge yang memisahkan tiga status assurance secara eksplisit.

Mengapa wajib: Kompetitor sering menyamakan “sudah di-scan” dengan “sudah aman”. Tanpa pemisahan ini, Atumcell ikut klaim berlebihan. Ini fondasi positioning “prove, don’t claim”.

2.4 Attack Surface inventory

Inventaris aset internet-facing (subdomain, IP, cloud, related domain), filter, export CSV, daftar aset baru.

Mengapa wajib: Continuous assurance tidak mungkin tanpa mengetahui apa yang terekspos. Coverage gap (unscanned) harus terlihat agar monitoring tidak menjadi theater.

2.5 Findings + detail teknis & dampak bisnis

Severity, KEV, SLA, owner, evidence, langkah reproduksi, dampak bisnis, saran remediasi.

Mengapa wajib: Engineer butuh bukti untuk memperbaiki; CISO butuh dampak bisnis untuk prioritas. Tanpa detail, validasi manusia tidak punya konteks.

2.6 Label human-validated di UI

Setiap temuan bertanda verified / pending / automated; metadata validator & metode.

Mengapa wajib: Diferensiator utama vs rating/EASM. Rapid7 Vector Command punya human validation di operasi, tetapi label eksplisit di UI jarang ditonjolkan sebagai kontrak produk. Label ini membuat “manusia” terlihat oleh buyer, bukan hanya di laporan belakang layar.

2.7 Human validation queue + kuota + KEV/emergent

Request validasi mengurangi kuota; retest remediasi tidak; antrian KEV dengan SLA ketat.

Mengapa wajib: Kapasitas manusia terbatas. Tanpa kuota & prioritas KEV, SLA jebol atau semua temuan “menunggu manusia” tanpa urutan. Model ini juga menjaga ekonomi layanan pentest Atumcell.

2.8 Remediation kanban + verified closure

Kolom: New → Assigned → In progress → Awaiting verification → Closed verified. Hard rule: masuk Closed verified hanya lewat verifikasi, bukan drag bebas.

Mengapa wajib: Banyak tools mengizinkan “mark as fixed” tanpa bukti. Aturan penutupan memaksa retest — inti kata “assurance”. Tanpa ini, produk kembali menjadi ticketing vulnerability biasa.

2.9 Closure certificate (sertifikat penutupan)

Artefak bertanggal: finding ID, validator, tanggal, penanda integritas (hash/metadata).

Mengapa wajib: Auditor, underwriter, dan IC PE butuh lampiran, bukan screenshot dashboard. Sertifikat adalah keluaran yang jarang ada di Bitsight/EASM/Rapid7 Exposure — pembeda unik yang bisa dijual.

2.10 Testing cycle (monitoring ↔ pentest)

Usulan scope dari monitoring, riwayat uji, next pentest window, scope rules.

Mengapa wajib: Menghubungkan bisnis pentest Atumcell ke produk SaaS. Tanpa siklus ini, CA hanya “scanner + badge”. Dengan siklus, monitoring memberi makan engagement pentest berikutnya secara berkelanjutan.

2.11 Evidence readiness (sempit, teknis)

Progress CIS / SOC2 teknis / ISO Annex A teknis / NIS2–DORA subset / binder asuransi — dengan disclaimer: bukan compliance platform penuh.

Mengapa wajib: Buyer sering ditanya “bukti untuk audit/asuransi”. Modul ini menjawab tanpa meniru Vanta. Batas sengaja sempit agar tidak scope-creep.

2.12 Reports multi-audiens + insurance binder

Template executive, technical, PE IC, dan binder underwriter asuransi.

Mengapa wajib: Satu data, banyak penerima. Binder asuransi adalah diferensiator GTM — menghubungkan remediasi terverifikasi ke keputusan underwriting.

2.13 PE Portfolio + due diligence

KPI dana, perusahaan berisiko, matriks, pipeline DD, drill-down tenant.

Mengapa wajib: Sponsor PE tidak membeli “satu company scanner”; mereka butuh roll-up portofolio. Rapid7 jarang menonjolkan modul PE mid-market seperti ini. Membuka jalur GTM kedua di luar CISO tunggal.

2.14 Assurance cycle strip (Discover → Validate → Prioritize → Remediate)

Navigasi proses di UI, deep-link ke modul terkait.

Mengapa wajib: Membantu user memahami produk sebagai siklus, bukan kumpulan halaman. Selaras bahasa CTEM/Rapid7 Vector, memudahkan perbandingan di sales.

3. PETA KOMPETITOR (PASAR LUAS)

TIPE	CONTOH	YANG MEREKA KUAT	CELAH UNTUK ATUMCELL
Security ratings	Bitsight, SecurityScorecard, UpGuard rating	Skor & grade eksekutif; easy board story	Validasi exploit manusia jarang; penutupan jarang bertanggal
EASM / CTEM otomatis	CyCognito, Halo, sebagian UpGuard	Inventaris surface luas; discovery otomatis	Klaim “otomatis = selesai”; noise tinggi
PTaaS	Cobalt, Synack, HackerOne (sebagian)	Manusia + retest kuat	Engagement-based; kurang continuous monitoring + PE roll-up
Compliance automation	Vanta, Drata	Kebijakan, employee, vendor, connector	Lemah di bukti teknis eksternal yang tervalidasi manusia
Rapid7	Exposure Command + Vector Command	Platform CTEM + continuous red team	Enterprise-heavy; sertifikat & PE mid-market kurang menonjol

4. FOKUS RAPID7 — CARA MEMBACA PRODUK MEREKA

4.1 Exposure Command

Platform CTEM hybrid: menggabungkan InsightVM, Surface Command, cloud/assessment otomatis, prioritisasi, dan (di tier Ultimate) agen/CNAPP serta ratusan konektor.

- **Kekuatan:** cakupan luas hybrid (external + internal/cloud), otomasi prioritas, ekosistem enterprise.
- **Bukan analog utama kita:** meniru Exposure Command Ultimate berarti perang fitur agent/CNAPP — di luar fokus Atumcell v1 dan di luar diferensiator pentest.

4.2 Vector Command (analog terdekat)

Layanan/produk continuous red team + external recon + validasi manusia + pelaporan cepat (same-day report). Lebih dekat ke “assurance dengan manusia” daripada scanner murni.

- **Kekuatan:** human exploit validation berkelanjutan; siklus discover→remediate; emergent threats.
- **Celah yang kita isi:** label human-validated yang eksplisit di UI produk mid-market; sertifikat penutupan sebagai artefak; modul PE portfolio + DD; binder asuransi sebagai output GTM; positioning lebih ringan (agentless eksternal) untuk mid-market.

Keputusan produk: “Paling dekat ke Vector Command, sengaja tidak mengejar Exposure Command Ultimate.” Ini mencegah scope creep dan menjaga narasi Atumcell sebagai continuous assurance berbasis validasi manusia.

5. MATRIKS KEMAMPUAN: RAPID7 VS ATUMCELL CA

● = kuat / ada · ◐ = parsial — = tidak / bukan fokus

CAPABILITY	EXPOSURE CMD	VECTOR CMD	ATUMCELL CA
External attack surface	●	●	●
Human exploit validation	◐	●	●
Human-validated label di UI	—	◐	● diferensiator
Closure certificate bertanggal	—	—	● unik
Siklus Discover→Remediate	◐	●	●
Emergent / KEV queue	●	●	●
Overall risk score + top issues	●	●	● (wajib di overview)
CNAPP / agent hybrid	●	—	— sengaja tidak
PE portfolio + due diligence	—	—	●
Insurance underwriter binder	—	—	●
Target segmen	Enterprise platform	Managed continuous RT	Mid-market + PE

5.1 Ringkas: di mana kita menang / kalah vs Rapid7

VS	KITA RELATIF LEBIH KUAT	MEREKA RELATIF LEBIH KUAT
Vector Command	Artefak sertifikat; label UI; PE + asuransi; fokus mid-market yang lebih tajam di mock-up	Brand enterprise, skala operasi continuous red team global, kematangan delivery
Exposure Command	Kesederhanaan narasi (agentless + manusia); tidak memaksa buyer masuk platform besar	Hybrid coverage, connector/agent, prioritas otomatis skala enterprise

6. POSITIONING ONE-LINER

Atumcell Continuous Assurance = **pantau terus, buktikan dengan manusia, tutup dengan sertifikat** — untuk mid-market dan sponsor PE. Paling dekat ke Rapid7 Vector Command, tanpa mengejar Exposure Command sebagai CNAPP/CTEM platform penuh.

7. IMPLIKASI UNTUK MOCK-UP & DISKUSI BERIKUTNYA

1. Overview harus memimpin dengan **overall risk score + top issues to remediate** (feedback Matthew).
2. Jangan jual CA sebagai “Bitsight + Vanta”; jual sebagai assurance yang bisa dilampirkan.
3. Dalam demo ke Rapid7-aware buyer: sebut Vector Command sebagai analog, lalu tunjukkan sertifikat, label validasi, dan PE.
4. Keputusan terbuka tetap: buyer utama (CISO vs PE), hubungan ke AtumScan/AtumScreen/SpoofCheck, kedalaman human validation (triage vs continuous RT vs hybrid).

— Akhir dokumen · Atumcell Continuous Assurance · Fitur, alasan & positioning kompetitor v1.0 —